

BrightBean YouTube API Audit Dossier

Prepared for Google OAuth verification and YouTube API Services compliance review

Application: BrightBean Social Studio

Production domain: studio.shopauth.cloud

Prepared: August 2, 2026

This supporting PDF is a point-in-time snapshot. The live public policies and the deployed application are authoritative for the review.

Google OAuth verification submission

App configuration

Field	Value
Google Cloud project ID	micro-reef-504311-n9
App name	BrightBean Social Studio
User type	External
Publishing status	Production before submission
App home page	https://studio.shopauth.cloud/youtube-integration/
Privacy Policy	https://studio.shopauth.cloud/privacy/
Terms of Service	https://studio.shopauth.cloud/terms/
Authorized domain	shopauth.cloud
User support email	admin@shopauth.cloud
Developer contact email	admin@shopauth.cloud plus an actively monitored project-owner address
OAuth client type	Web application
Authorized redirect URI	https://studio.shopauth.cloud/social-accounts/callback/youtube/

The OAuth consent screen, public product page, app UI, and demo narration must all use the same product name: BrightBean Social Studio. If the Google Cloud console currently shows shopauth.cloud, update it before recording the final demo.

App purpose

BrightBean Social Studio is a web-based content-planning and publishing workspace for channel owners and authorized social-media teams. A user connects a YouTube channel through Google OAuth, selects a target channel, prepares a video or Short with a title, description, tags, made-for-kids setting, and explicit public/unlisted/private visibility, and then initiates or schedules the upload. Authorized users can also manage YouTube comments and review channel and video analytics inside their workspace.

The integration does not download YouTube media, scrape YouTube, sell Google user data, create surveillance profiles, manipulate engagement, or publish without a user-selected target and publication settings.

Paste-ready scope summary

BrightBean Social Studio requests four YouTube scopes to provide implemented, user-facing features: upload of user-selected videos and Shorts; identification and display of the user's selected channel; comment viewing, posting, replying and moderation; and owner-authorized channel/video analytics. Each action is initiated by an authorized workspace user. Tokens are encrypted, authorization is checked regularly, raw upload API responses are not retained, and disconnecting the channel revokes the grant and deletes stored YouTube API data. Detailed per-scope explanations are in `scope_justifications.md`.

Demo video requirements

The final unlisted reviewer video must show, in one continuous and legible recording:

- The public application home page and legal links.
- Sign-in to the BrightBean reviewer account.
- Social Accounts → YouTube → Connect.
- The Google OAuth screen showing the same app name and every requested scope.
- Selection of the reviewer-owned YouTube channel.
- Composer setup for a Short, including title, description, tags, made-for-kids setting, and visibility selector.
- A private test upload initiated by the reviewer account.

- The completed BrightBean status and matching private video in YouTube Studio.
- The analytics and comments surfaces that justify the read, force-ssl, and analytics scopes.
- The in-product Disconnect control and the Data Deletion page. Do not actually disconnect the production channel in the final take unless a dedicated test connection is used.

Owner inputs required before submission

- [OWNER INPUT REQUIRED] Confirm the legal entity/person responsible for ShopAuth Cloud and ensure the same identity is used where Google asks for organization details.
- [OWNER INPUT REQUIRED] Confirm an actively monitored Google Cloud project-owner/editor email.
- [OWNER INPUT REQUIRED] Verify domain ownership for shopauth.cloud in Google Search Console using a project owner or editor.
- [OWNER INPUT REQUIRED] Confirm the app logo and brand name match the public page and OAuth consent screen.
- [OWNER INPUT REQUIRED] Create a dedicated reviewer account and test YouTube channel; provide credentials only in the secure submission form.

YouTube API Services audit — paste-ready answers

Request type

Select the option for an API compliance audit required for an unverified API project / public upload access. Do not request additional quota unless the product actually needs more than the existing quota.

Applicant and organization

- Applicant name: [OWNER INPUT REQUIRED: full legal name]
- Organization/legal entity: [OWNER INPUT REQUIRED: exact registered name or state that this is an individual/sole trader]
- Address: [OWNER INPUT REQUIRED]
- Phone: [OWNER INPUT REQUIRED]
- Contact email: admin@shopauth.cloud plus the actively monitored Google Cloud project owner address
- Website: <https://studio.shopauth.cloud/youtube-integration/>

API project and client

- Google Cloud project ID: micro-reef-504311-n9
- Google Cloud project number: [OWNER INPUT REQUIRED: copy from Google Cloud Project info; do not infer from the client ID]
- API client name: BrightBean Social Studio
- API client type: server-side web application
- Production URL: <https://studio.shopauth.cloud/>
- Public product page: <https://studio.shopauth.cloud/youtube-integration/>
- Privacy Policy: <https://studio.shopauth.cloud/privacy/>
- Terms of Service: <https://studio.shopauth.cloud/terms/>
- Data Deletion: <https://studio.shopauth.cloud/data-deletion/>
- OAuth redirect URI: <https://studio.shopauth.cloud/social-accounts/callback/youtube/>

Detailed use case

BrightBean Social Studio is a web-based social-media content-planning, approval, scheduling, publishing, comment-management and analytics workspace. A channel owner or authorized team member signs in to BrightBean, opens Social Accounts, and explicitly connects a YouTube channel through Google's OAuth consent flow. BrightBean retrieves the authenticated channel identity so the user can confirm the target.

For publishing, the user selects a video file, chooses the connected YouTube channel, reviews or enters the video title and description, optionally sets tags and a custom thumbnail, declares whether the content is made for kids, and explicitly selects Public, Unlisted or Private visibility. The user then initiates immediate publication or sets a schedule. BrightBean uses the resumable videos.insert upload flow and stores the returned YouTube video ID as the publication result. BrightBean does not retain the full raw upload response.

When the user enables comments and analytics, BrightBean lets the authorized channel team view and reply to YouTube comments and view YouTube-labeled channel/video analytics. YouTube API data is visible only to the channel owner or authorized members of that workspace. The client does not scrape, download YouTube media, sell API data, profile viewers, manipulate engagement, or create derived YouTube scores.

How users initiate YouTube actions

Every OAuth connection is initiated by a user with workspace permission to manage social accounts. Every upload has a selected YouTube target and a visible composer panel for title, description, tags, made-for-kids status and privacy. Public, unlisted and private are separate choices. Immediate upload or scheduled upload follows a user submit action. Comment replies and moderation are initiated from the YouTube-labeled inbox. BrightBean does not change an existing video's visibility without explicit user selection.

Data storage and retention

OAuth tokens are encrypted. Channel identity/profile data is refreshed during authorization health checks, normally every six hours. YouTube analytics/statistics may be retained as dated historical data while the channel remains authorized and the metrics are needed to provide the owner-requested analytics feature; authorization is reconfirmed at least every 30 days. Other YouTube Authorized Data is refreshed or deleted within 30 days. Raw upload API responses are not retained.

In-product disconnect attempts immediate programmatic token revocation and deletes the connected-account record and related API-derived publishing/analytics data. If BrightBean detects that YouTube authorization can no longer be verified, it stops new access, retries health checks during a recovery window, and automatically deletes the connected YouTube API data after no more than 30 days. Users can also request deletion by email or revoke access from Google's third-party connections settings.

Expected API usage

- Product-level safety limit: maximum 6 YouTube publishes per connected account per day unless an explicit per-account administrative override is configured.
- Standard project quota assumption: 10,000 quota units/day.
- One resumable `videos.insert` flow per user-approved upload.
- Channel profile/authorization health check: normally every 6 hours per active account.
- Account analytics: normally daily.
- Video analytics: hourly for posts under 24 hours, every 6 hours for posts aged 1–7 days, daily for posts aged 7–30 days, weekly for posts aged 30–90 days, then background refresh stops.
- Initial rollout: a small number of owner-managed channels. [OWNER INPUT REQUIRED: provide realistic expected connected-channel count for 3, 6 and 12 months.]

Quota request

No additional quota is requested in this submission unless the owner selects otherwise. The goal is the compliance audit needed to permit user-selected public/unlisted uploads from the production project. If the form requires a numeric request, use the current default quota and explain that no extension is requested.

User control and deletion

Users can disconnect a channel from Social Accounts. BrightBean immediately removes the connection and stored YouTube API data and attempts to revoke the OAuth grant. The Privacy Policy links to Google's third-party connections settings. BrightBean explains that deleting BrightBean-held data does not delete content held independently on YouTube.

Demo access

- Reviewer login URL: `https://studio.shopauth.cloud/accounts/login/`
- Reviewer email: [OWNER INPUT REQUIRED: dedicated reviewer account]
- Reviewer password: [PROVIDE ONLY IN THE FORM'S SECURE FIELD; NEVER COMMIT]
- Reviewer YouTube channel: [OWNER INPUT REQUIRED: dedicated test channel name and URL]

- Instructions: sign in, open Social Accounts, connect/select the reviewer-owned YouTube channel, then open Publish/New to view the YouTube composer settings. A preloaded harmless test MP4 should be available. Use Private visibility for the review upload unless the reviewer requests otherwise.

Attached evidence

Attach the combined audit dossier PDF and, if the form permits, the scope-justification PDF. Provide the unlisted demo-video URL in the video field. Legal policies should be submitted as live public URLs; PDFs are supporting snapshots, not replacements for public pages.

OAuth scope justifications

`https://www.googleapis.com/auth/youtube.upload`

BrightBean Social Studio uses this scope to upload a video or Short selected by the signed-in user to the YouTube channel that the user connected. Before upload, the composer lets the user review and set the title, description, tags, made-for-kids declaration, and public/unlisted/private visibility. The user explicitly initiates immediate publication or chooses a schedule. A narrower read-only scope cannot upload the user's media.

Demo evidence: connect the reviewer channel, open the composer, select a test MP4, show all YouTube settings, choose Private, initiate the upload, and show the matching private video in YouTube Studio.

`https://www.googleapis.com/auth/youtube.readonly`

BrightBean Social Studio uses this scope to retrieve the authenticated user's own channel identity and current channel metadata so the user can verify the correct publishing target. The product displays the channel name, handle, avatar and owner-authorized channel statistics, and uses the YouTube video ID to retrieve current status and metrics for videos published through the workspace. The upload-only scope does not provide the read access needed to identify the selected channel or display current channel/video state.

Demo evidence: after OAuth, show the connected channel card with the same channel name and handle as YouTube Studio, then show a YouTube-specific analytics view with source labels.

`https://www.googleapis.com/auth/youtube.force-ssl`

BrightBean Social Studio uses this scope for implemented comment-management features on the authorized user's channel: reading comment threads, posting a first comment when requested, replying to comments, and moderating comments from the Social Inbox. These write actions require an authorized YouTube scope; `youtube.readonly` cannot create replies or perform moderation. BrightBean does not use this scope to subscribe, like, or manipulate engagement.

Demo evidence: open the YouTube comments/inbox surface, show a comment thread, post a harmless test reply on the reviewer-owned private/unlisted test content if supported, and show the corresponding result in YouTube Studio. If the deployed UI does not expose all of these actions at submission time, remove this scope from both code/consent configuration or finish the UI before submitting.

`https://www.googleapis.com/auth/yt-analytics.readonly`

BrightBean Social Studio uses this read-only scope to display owner-authorized YouTube channel and video analytics such as views, estimated minutes watched, average view percentage, subscriber changes and shares. Analytics are shown only to the channel owner or authorized workspace members and are clearly labeled as YouTube data. The YouTube Data API read scope does not provide YouTube Analytics reports such as watch time or average view percentage.

Demo evidence: open Analytics, select the connected YouTube channel, show the YouTube-labeled metrics and date range, and explain that the scope is read-only. If YouTube analytics is disabled in production at submission time, remove this scope from the OAuth consent screen and do not include it in the request.

Minimum-scope decision

All four scopes correspond to currently implemented product functions. No scope is requested for future features.

BrightBean does not request broad Google account, Gmail, Drive, Photos, viewing-history, subscription-management, or monetization scopes.

YouTube and Google data handling matrix

Data or action	Source / scope	Product purpose	Stored	Refresh / retention	Shared	Deletion
OAuth access and refresh tokens	Google OAuth; all authorized scopes	Authenticate requests approved by the user	Encrypted database fields	Kept only while the connection is active; authorization normally checked every 6 hours	Google endpoints only, plus infrastructure processors needed to run the service	In-product disconnect revokes the grant and removes the account immediately; invalid authorization is purged within 30 days
Channel ID, name, handle, avatar	YouTube Data API; youtube.readonly	Identify the selected channel in the workspace	Connected-account record	Refreshed during health checks, normally every 6 hours and at least every 30 days	Authorized workspace users; infrastructure processors	Cascade-deleted with the connected account
Subscriber, view and video counts	YouTube Data API; youtube.readonly	Current channel statistics	Current account value and/or dated analytics snapshots	Current profile value refreshed during health checks; historical statistics retained only while authorization is valid and needed	Channel owner or authorized workspace members	Cascade-deleted with the connected account
User-selected upload media	User upload plus youtube.upload	Publish the selected video/Short	BrightBean media library according to workspace retention	User-controlled workspace content; not YouTube API data until transmitted	YouTube for the requested upload; configured storage/video processors as disclosed	User deletes media/workspace, or requests account deletion
Title, description, tags, category, made-for-kids and visibility	User input; youtube.upload	Configure the requested upload	Publishing record	Kept as user-authored publishing history	YouTube for the requested upload; authorized workspace users	Deleted with the publishing record/workspace
YouTube video ID and publishing state	YouTube upload response	Link the local publishing result to the YouTube resource	PlatformPost.platform_post_id and status fields	Kept as publishing history while the connection/workspace exists	Authorized workspace users	Deleted with the connected account or workspace
Raw upload API response	YouTube Data API	Not required after upload	Not retained after this compliance change	Existing rows are scrubbed by migration	Not shared	Removed by migration; new responses are discarded
Comment IDs, authors, text, threads and replies	YouTube Data API; youtube.force-ssl	User-requested inbox, reply and moderation features	Inbox/publishing records as needed for the feature	Refreshed through product sync; deleted with account/workspace	Authorized workspace users; YouTube for write actions	Deleted with the connected account or applicable data-deletion request
Views, watch time, average view percentage, subscriber changes, likes, comments and shares	YouTube Data/Analytics APIs; read and analytics scopes	Channel-owner analytics	Dated snapshots	Recent videos refreshed hourly-to-weekly based on age; background post sync stops after 90 days; historical authorized statistics may remain while authorization is reconfirmed at least every 30 days	Channel owner or authorized workspace members	Cascade-deleted with the connected account; invalid authorization purged within 30 days
Logs and security events	BrightBean infrastructure	Security, abuse prevention and troubleshooting	Restricted operational logs	Limited logs/backups rotate within up to 90 days as disclosed	Authorized operators and infrastructure processors	Rotation or legal/security exception described in Privacy Policy

BrightBean does not store Google passwords, YouTube viewing history, private subscriptions, financial/monetization data, or independently derived YouTube scores. It does not sell Google user data or use it for advertising or generalized AI-model training.

Security and retention controls

Implemented controls

- OAuth access and refresh tokens are stored in encrypted database fields.
- OAuth state is signed, tied to the workspace/user/platform, and time-limited.
- The Google OAuth callback URI is HTTPS and fixed to the production domain.
- Social-account management requires authentication and the `manage_social_accounts` permission.
- YouTube actions are scoped to a selected workspace and connected account.
- Composer validation restricts YouTube visibility to public, unlisted, or private and title length to YouTube's 100-character limit.
- The service requests no Google password and does not log token values.
- Connected-account authorization is normally verified every six hours.
- Confirmed YouTube authorization failures start a 30-day recovery/deletion clock; successful reauthorization clears the clock.
- A daily task deletes connected YouTube API data after 30 days of continuously invalid authorization.
- In-product disconnect revokes the OAuth grant and immediately deletes the connected account and related API-derived data.
- Organization hard deletion attempts token revocation before cascade deletion removes credentials.
- The full raw YouTube upload response is no longer retained; a migration scrubs response payloads from existing YouTube publishing rows while preserving user-selected publishing settings.
- Analytics records and publishing records cascade-delete with the connected social account.

Operational controls required at deployment

- Run migrations before enabling the new code path.
- Run the background-task worker continuously so the six-hour authorization checks and daily retention purge execute.
- Restrict production environment and database access to authorized operators.
- Keep the Google OAuth client secret only in the production secret store/environment; never in the repository or audit attachments.
- Keep Google Cloud project owner/editor contacts current and monitor review mail.
- Review failed health-check and retention-purge logs without recording token values.
- Re-run the evidence checklist after any change to scopes, redirect URI, domain, app name, logo, privacy URL, or YouTube feature set.

Deletion behavior

Disconnecting in BrightBean affects BrightBean-held authorization and data. It does not delete videos or other content held independently by YouTube. The public Data Deletion page explains that users must use YouTube controls to delete YouTube-hosted content.

Pre-submission evidence checklist

Deployment and public identity

- ☐ Current branch reviewed and deployed to production.
- ☐ Migration 0013_youtube_authorization_retention applied successfully.
- ☐ Background worker running and both recurring tasks registered: schedule_all_health_checks and purge_invalid_youtube_authorizations.
- ☐ <https://studio.shopauth.cloud/youtube-integration/> returns HTTP 200 without login and describes the app.
- ☐ Privacy, Terms and Data Deletion URLs return HTTP 200 without login and show “Effective and last updated: August 2, 2026”.
- ☐ Public pages use the same product name and logo as the OAuth consent screen.
- ☐ shopauth.cloud ownership verified in Google Search Console by a Google Cloud project owner/editor.

Google Cloud configuration

- ☐ Correct project selected: micro-reef-504311-n9.
- ☐ YouTube Data API v3 and YouTube Analytics API enabled.
- ☐ OAuth app user type External and publishing status Production.
- ☐ Home page, Privacy Policy and Terms URLs exactly match this package.
- ☐ Authorized domain includes shopauth.cloud.
- ☐ Web-client redirect URI exactly matches <https://studio.shopauth.cloud/social-accounts/callback/youtube/> including scheme and trailing slash.
- ☐ Scope list exactly matches the scopes requested by the production app.
- ☐ User support and developer-contact emails are monitored.
- ☐ No client ID/secret mismatch between Google Cloud and production secret configuration.

Product behavior

- ☐ Connect flow shows Google OAuth under the BrightBean Social Studio name.
- ☐ Connected channel identity matches YouTube Studio.
- ☐ Composer requires/shows title, description, made-for-kids and visibility controls.
- ☐ Public, Unlisted and Private options are visible before submit.
- ☐ A private test Short uploads and reaches processed/succeeded state.
- ☐ No automatic #Shorts or other undisclosed text is appended to the user title/description.
- ☐ YouTube analytics are labeled and shown only to authorized workspace users.
- ☐ Comment UI is live if youtube.force-ssl is requested.
- ☐ In-product Disconnect is easy to find.
- ☐ Disconnect on a test connection revokes/removes the grant and deletes the local account data.

Evidence files

- ☐ Screenshot: public product page with URL.
- ☐ Screenshot: Privacy Policy Google/YouTube section and Limited Use statement.
- ☐ Screenshot: Data Deletion page and Google security-settings link.
- ☐ Screenshot: OAuth consent app name, domain and full scope list.
- ☐ Screenshot: connected channel card beside matching YouTube Studio channel.
- ☐ Screenshot: composer YouTube panel with visibility selector.
- ☐ Screenshot: completed private upload in BrightBean and YouTube Studio.
- ☐ Screenshot: YouTube-labeled analytics.
- ☐ Screenshot: YouTube comment/reply surface.
- ☐ Unlisted reviewer demo URL accessible in an incognito window.
- ☐ Combined dossier PDF and scope-justification PDF each under 10 MB.

Final consistency check

- ☐ App name, URLs, project ID, scopes, use-case copy and demo all agree.
- ☐ Every described feature is available to the reviewer account.
- ☐ Every requested scope is visibly demonstrated.
- ☐ Owner/legal identity and expected user/channel counts are filled with real values.
- ☐ Demo credentials are supplied only through Google's secure form, never in Git or PDFs.
- ☐ Submit OAuth verification and YouTube API compliance audit separately, then monitor the project-owner inbox and spam folder for reviewer questions.